

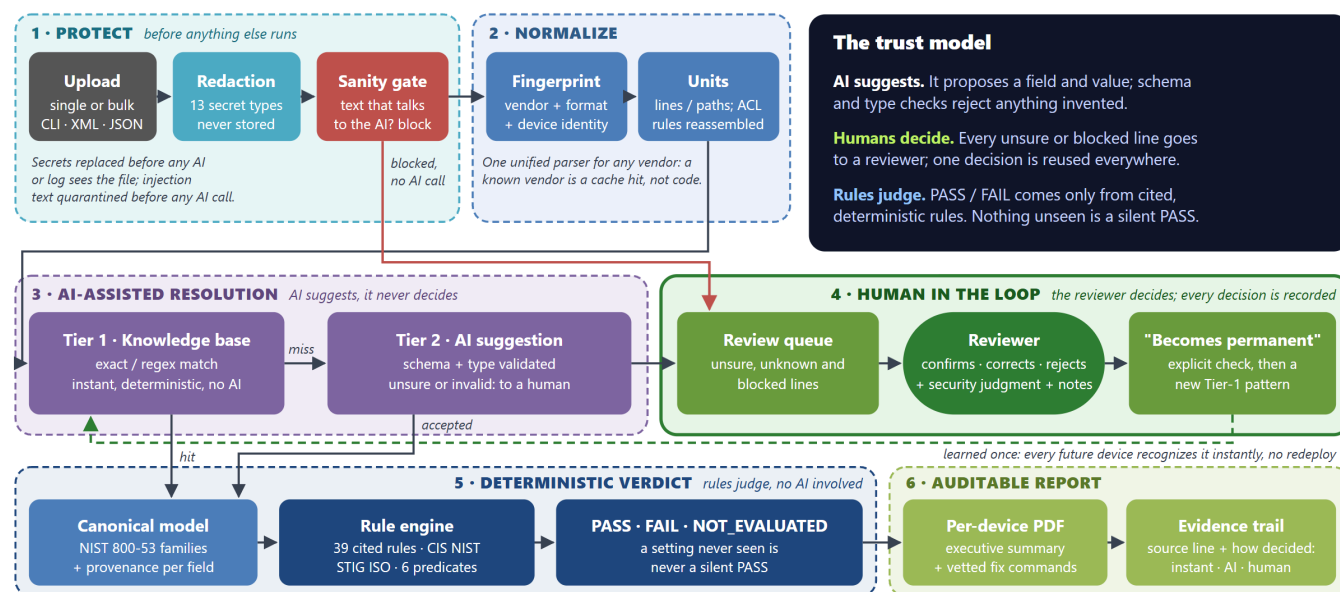
AEGIS: Architecture Document

Automated Evaluation & Governance for Infrastructure Security: an AI-augmented, vendor-agnostic network compliance engine

The problem, and the one design decision that answers it

Network devices from dozens of vendors must be checked against CIS, NIST SP 800-53, DISA STIG and ISO/IEC 27001, but every vendor's syntax differs, and a hardcoded parser per vendor breaks on the next vendor, firmware or device class. **AEGIS has one resolution path for every vendor: a lookup against one knowledge base (KB).** Only format handling is code, and it is generic (CLI lines, brace- and block-structured CLI, XML, JSON). A new vendor is learned in the review queue: its lines are taught once, and the reviewer names the vendor from a line of its own config header, giving it its own KB bucket. A vendor's knowledge can also be pre-loaded in bulk as one YAML file (fingerprint, patterns, defaults), as done for Juniper Junos and FortiGate. Neither needs new code or a redeploy.

Pipeline



- Redaction first.** Secret-shaped values (enable/user hashes, type-7 and plain passwords, SNMP communities and SNMPv3 keys, IPsec PSKs, RADIUS/TACACS+ keys, routing keys, FortiOS ENC and Junos quoted secrets, XML/JSON secret fields) become typed placeholders before anything else runs. Originals live only in memory for one request: never stored, logged or sent to an AI. The type digit stays visible because rules need it.
- Fingerprint + identity.** Vendor, format, hostname, model, serial, firmware (e.g. Cisco license udi ... sn ...), and the SHA-256 of the uploaded file. Unrecognized vendors are not rejected; they route through Tiers 2/3.
- Units with context.** One unit per setting; nested CLI keeps its parent path (set system services telnet). Banner text and free-text fields are never classified.
- Input-sanity gate.** Config text is attacker-influenceable. Any unit shaped like an instruction to an AI is quarantined to human review *before any AI call* and shown as a blocked attack. Deterministic by design (an LLM filter has the same injection surface). A second, structural layer: free-text fields (descriptions, remarks) never reach the AI at all.
- Confidence-tiered resolution:**
 - Tier 1:** exact/regex KB match: instant, deterministic, including known non-security structure.
 - Tier 2:** an AI model proposes {field, value, confidence} for ~12 lines per call, in parallel, cached (8-17 s per fresh file on free tiers). Groq then Gemini, or **your own model** (AEGIS_LLM_MODE=local, air-gapped), or none (off). Output is schema- and type-validated: invented fields or a value whose type contradicts the field are rejected.
 - Tier 3:** anything rejected, unsure or unavailable goes to a reviewer. A confirmation becomes a new pattern, recorded as *human-confirmed*, and is hash-chained (/audit/verify detects any later edit).
- Canonical model** on NIST 800-53 families (AC/AU/IA/SC/CM), so CIS, STIG and ISO share one schema. When a setting appears several times, the least secure value counts, and every source line is kept as evidence.

7. **Deterministic rule engine:** no AI in the verdict path. Six predicate types; ACLs are evaluated in order, per list, and only lists the device applies. A deny must cover all the traffic in question; an unreadable line before the decision yields *unknown*, never PASS. **39 hand-written rules** across the four frameworks, plus **96 rules from imported official DISA STIG releases** (101 of 267 STIG rules automated, the rest reported as manual; `stig_sync` detects new releases and sets aside any rule whose check text changed). **Asymmetric trust:** AI-derived evidence may FAIL a control but never PASS one without a human; a vendor's documented default (when the config is silent) may FAIL a rule, never PASS one.
8. **Remediation + PDF.** Fixes come only from vetted templates, filled with the device's own failing ACL and wrapped as a paste-in change. The PDF shows an integrity panel (input SHA-256, rule-set fingerprint, findings digest), the evidence line behind every finding, how it was decided, and why anything is unknown.

What makes it defensible, not just functional

- **Fail-closed by construction.** `NOT_EVALUATED` is a first-class verdict: a setting that is absent, unreadable, awaiting review or only AI-read is never a pass.
- **Every trust boundary is enforced in code.** Secrets redacted before inference; injection text never reaches the model; model output type-checked; verdicts deterministic; reviewer decisions validated, attributable (optional reviewer tokens) and tamper-evident.
- **Measured, errors included.** 73 verdicts hand-labelled from the config text over 7 configs and 5 vendors: **73 of 73 correct, 0 false PASS or FAIL**, with the AI off or on; CI fails the build on any wrong verdict. Prompt injection: the gate catches 32/32 tuned and **12/20 held-out** variants with 0 false positives on 416 real lines, and **0 of 52** attacks reach the AI end to end. **Held-out real configs** (7 public Batfish/NAPALM/netutils configs, labels committed before the first run): first run **0 false PASS**, 33/35 decided correct; on the current build **41/41**, AI off and live, 15 of 56 left unknown rather than guessed. One live run between fixes gave a false PASS from an AI misreading; AI-only evidence now never passes any control. Classifier: 95.8% precision on auto-accepted mappings (33-line golden set). Four adversarial review rounds found false-PASS paths (e.g. an interface QoS policy read as control-plane protection, an unapplied ACL counted, Junos deactivated statements); every one is fixed and is now a regression test (314 offline tests in CI).

Tech stack

FastAPI (Python 3.11) · SQLAlchemy on SQLite (Postgres + pgvector is the production path) · local `sentence-transformers` embeddings · Groq `qwen3.8-27b` + Gemini 2.5 Flash, or any OpenAI-compatible local model · ReportLab · Langfuse · Next.js 16 + Tailwind · pytest + GitHub Actions.

Honest scope of this build

Not built yet: cross-reference linking by name (Cisco AAA method lists; Cisco ACL bindings, SONiC ACL rows, pfSense rules and FortiGate policies already are); vendor defaults beyond Cisco IOS, Junos and FortiOS; per-interface CDP (proxy ARP is per interface); entropy-based redaction; a login UI and roles; a job queue; live collection (Netmiko). Rule coverage is partial and stated per benchmark (101/267 DISA STIG rules automated); CIS and ISO content is licensed, so those stay hand-written slices. ISO/NIST results are device-level evidence supporting a control, not a certification; CAT levels on CIS/NIST/ISO rules are AEGIS-assigned on the STIG scale. Local-model mode is covered by tests, not yet benchmarked on a real local model.